



DAS Policy

No:
2100-10

Identification and Authentication

Effective:
April 29, 2025

Approval:

Katrina Flory, Assistant Director/State CIO

I. Purpose

The purpose of this policy is to provide **Identification** and **Authentication** (I&A) requirements for Ohio Department of Administrative Services (**DAS**)-**managed system assets**. Documented I&A controls are needed to ensure proper **User** provisioning and de-provisioning.

The first occurrence of the word in the policy body outside of a title or heading is in bold, italic type, and is hyperlinked to the definition in Section IV. In addition, references to National Institute of Standards in Technology (NIST) Special Publication (SP) 800-53 family Identifiers and control numbers are provided in parentheses next to requirement headers, where applicable. The requirements of the NIST SP 800-53 Identification and Authentication (IA) control family are addressed in this policy.

II. Scope

The scope of this policy includes any DAS-Managed System Asset. This policy also applies to DAS **Data Owners**, **Service Owners**, and extends to managed service providers.

Public information that is provided via the Internet does not require I&A.

III. Policy

A. Each DAS **Organizational** and **Non-Organizational User** shall be assigned a unique **Identifier** and shall be properly authenticated prior to gaining access to DAS-Managed System Assets.

1. Organizational User I&A (IA-2): I&A of Organizational User identities (e.g., employees, temporary contract workers, independent contractors and consultants) shall be

accomplished through the use of mechanisms such as passwords, **Tokens**, **Biometrics**, or **Multifactor Authentication**, or some combination thereof as dictated by Ohio IT Standard DAS-ITS-2100-01-A, "Password Standard for Organizational Users," and the following requirements:

- a) Organizational Users shall be maintained in a separate namespace or separate directory, container or database from Non-Organizational Users.
 - b) Multifactor Authentication is required for **Local**, **Network**, and **Remote Access** for **Privileged User** accounts.
 - c) Multifactor Authentication is required for network and Remote Access for non-Privileged User accounts.
 - d) Local Access from non-privileged accounts does not require Multifactor Authentication, but it is preferred.
 - e) Multifactor Authentication for Remote Access to privileged and non-privileged accounts requires one of the factors be provided by a device separate from the system gaining access.
 - f) **Replay-resistant Authentication Mechanisms** for Network Access to privileged accounts shall be employed based on the **Security Categorization** of the system.
2. Non-Organizational User I&A (IA-8): At a minimum, Non-Organizational Users are uniquely identified and authenticated for all accesses to non-public information or systems that contain **Confidential Data**.
- a) Authentication of Non-Organizational User identities shall be accomplished through the use of passwords, Tokens, Biometrics, or Multifactor Authentication, or some combination thereof as dictated by Ohio IT Standard DAS-ITS-2100-01-B, "Password Standard for Non-Organizational Users," the results of the **Risk Assessment** and the assigned data classification labels.
 - b) For Non-Organizational Users, different classes of Users shall be maintained in a separate namespace or separate directory, container or database (e.g., citizen/public and business entities shall be maintained separately).
- B. Use of Group Identifiers and **Authenticators**: Individuals authorized to use group Identifiers or Authenticators (e.g., shared accounts or Tokens used by multiple individuals to gain privileged access) are required to use them in a manner that provides detailed accountability.
1. At a minimum, each use of a group Identifier or Authenticator shall be logged capturing the time, date, individual, and group Identifier or Authenticator used. Logging can be accomplished through automated or manual means as dictated by system capability.
 2. Group Identifiers shall be tested prior to implementation and training shall be provided to Users.

- C. **Identifier Management (IA-4)**: System and Service Owners responsible for issuing and managing Identifiers shall establish procedures for authorizing and assigning organizational and Non-Organizational User Identifiers to the intended party.
1. Ensure that User Identifiers are unique.
 2. Identifiers for Organizational Users shall be disabled upon separation.
- D. **Authenticator Management (IA-5)**: System and Service Owners responsible for issuing and managing Authenticators shall develop procedures that address initial Authenticator distribution, revocation, protection from unauthorized disclosure and modification, and lost/compromised or damaged Authenticators for organizational and Non-Organizational Users.
1. As part of the initial Authenticator distribution process (e.g., the initial password), the identity of the individual receiving the Authenticator shall be verified prior to distribution. Identifiers and Authenticators shall be transmitted to Users separately and securely (e.g., using separate, encrypted emails). Initial Authenticators shall be randomly generated for each User and require change upon initial login.
 2. The reuse of Authenticators shall follow the requirements outlined in Ohio IT Standard DAS-ITS-2100-01-A, "Password Standard for Organizational Users" and DAS-ITS-2100-01-B, "Password Standard for Non-Organizational Users."
- E. **Authenticator Feedback (IA-6)**: During the Authentication process, Authentication information feedback shall be obscured (e.g., display asterisks when a User types in a password). This requirement will help protect information from possible exploitation or use by unauthorized individuals. The means for obscuring the Authenticator feedback shall be selected in accordance with the results of a Risk Assessment.
- F. **Device Identifiers (IA-3)**: System and Service Owners responsible for issuing and managing device Identifiers (e.g., workstations, laptops, tablets, smartphones, Voice over Internet Protocol (VoIP) phones, network hardware, and network devices) shall develop procedures addressing Identifier authorization and assignment. Device Identifiers shall be unique.
- G. **Exception Process**: To request an exception to one or more of the requirements outlined in this policy, please complete an IT Security Exception Request form.
- a) The form is located within the IT Enterprise Services Portal under the "Services & Products" category.

- b) If you have any questions, please contact DAS OISP (refer to Section VII. Inquiries for contact information).

IV. Definitions

- A. Authentication. Verifying the identity of a User, process, or device, often as a prerequisite to allowing access to resources in an information system.¹
- B. Authenticator. The means used to confirm the identity of a User, process, or device (e.g., User password or Token).²
- C. Availability. Ensuring timely and reliable access to and use of information.³
- D. Biometrics. A measurable physical characteristic or personal behavioral trait used to recognize the identity, or verify the claimed identity, of an applicant. Facial images, fingerprints, and iris scan samples are all examples of Biometrics.⁴
- E. Confidential Data. This classification includes Data that is required to be protected by law or regulation, is intended for confidential use, and may not be copied or removed from an agency's operational control without authorized permission. This classification includes Data that, if compromised, may result in loss of life, serious injury, or other harm to an individual or group, or disruption to critical agency operations.
- F. Confidentiality. Preserving authorized restrictions on information access and disclosure, including means for protecting personal privacy and proprietary information.⁵
- G. DAS-Managed System Asset. Information, hardware, software and services required to support state business, and identified during the Risk Assessment process as assets that need to be protected. Primary responsibility for managing these system assets may be assigned to DAS OIT personnel or other outside entities.
- H. Data Owner. The Data Owner is responsible for the Identification and classification of information, in consultation with Legal Counsel, and shall address the assignment of data classification labels, data compilation, data classification coordination, data classification compliance and data access. The role of a Data Owner and his/her associated responsibilities are addressed in detail within Ohio Administrative Policy IT-13, "Data Classification."

¹ "NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations," U.S. Department of Commerce National Institute of Standards and Technology, April, 2013 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

² "NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations," U.S. Department of Commerce National Institute of Standards and Technology, April, 2013 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

³ *Ibid.*

⁴ "FIPS PUB 201-2 Personal Identity Verification (PIV) of Federal Employees and Contractors," U.S. Department of Commerce National Institute of Standards and Technology, August 2013, <<https://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.201-2.pdf>>.

⁵ "NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations," U.S. Department of Commerce National Institute of Standards and Technology, April, 2013 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

- I. Identification. An act or process that presents an Identifier to a system so that the system can recognize a system entity (e.g., User, process, or device) and distinguish that entity from all others.⁶
- J. Identifier. A data object – often, a printable, non-blank character string – that definitively represents a specific identity of a system entity, distinguishing that identity from all others.⁷
- K. Integrity. Guarding against improper information modification or destruction, and includes ensuring information non-repudiation and authenticity.⁸
- L. Local Access. Access to an organizational information system by a User (or process acting on behalf of a User) communicating through a direct connection without the use of a network.⁹
- M. Multifactor Authentication. Authentication using two or more factors to achieve Authentication. Factors include: (i) something you know (e.g., password/PIN); (ii) something you have (e.g., cryptographic Identification device, Token); or (iii) something you are (e.g., biometric).¹⁰
- N. Network Access. Access to an information system by a User (or a process acting on behalf of a User) communicating through a network (e.g., local area network, wide area network, Internet).¹¹
- O. Non-Organizational User. A User who is not an Organizational User¹², which for the purposes of this policy includes public Users.
- P. Organizational User. An Organizational User is anyone who is an employee of the state, or is otherwise authorized to work on behalf of the State, and who has a need to access State of Ohio IT systems and has secured agency authorization for such access. The organizational Identifier will help to distinguish the individual during the Authentication process. Examples of resources that may fall into this category include full-time employees, part-time employees, seasonal employees, temporary contract workers, independent contractors or consultants, volunteers or unpaid interns. The Organizational User Identifier category may also include university and federal government resources.
- Q. Privileged User. A User that is authorized (and, therefore, trusted) to perform security-relevant functions that ordinary Users are not authorized to perform.¹³

⁶ “CNSS Instruction No. 4009, National Information Assurance (IA) Glossary,” Committee on National Security Systems, April 2010 <<https://www.hsdl.org/?abstract&did=7447>>.

⁷ “CNSS Instruction No. 4009, National Information Assurance (IA) Glossary,” Committee on National Security Systems, April 2010 <<https://www.hsdl.org/?abstract&did=7447>>.

⁸ “NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations,” U.S. Department of Commerce National Institute of Standards and Technology, April, 2013 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

⁹ *Ibid.*

¹⁰ *Ibid.*

¹¹ *Ibid.*

¹² *Ibid.*

¹³ “NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations,” U.S. Department of Commerce National Institute of Standards and Technology, April, 2013 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

- R. Remote Access. Access to an organizational information system by a User (or an information system acting on behalf of a User) communicating through an external network (e.g., the Internet).¹⁴
- S. Replay-resistant Authentication Mechanisms. Authentication processes resist replay attacks if it is impractical to achieve successful Authentications by replaying previous Authentication messages. Replay-resistant techniques include, for example, protocols that use nonces or challenges such as Transport Layer Security (TLS) and time synchronous or challenge-response one-time Authenticators.¹⁵
- T. Risk Assessment. The process of identifying, prioritizing, and estimating risks to organizational operations (including mission, functions, image, and reputation), organizational assets, individuals, other organizations, and the Nation, resulting from the operation of an information system.¹⁶
- U. Security Category. The characterization of information or an information system based on an assessment of the potential impact that a loss of **Confidentiality, Integrity, or Availability** of such information or information system would have on organizational operations, organizational assets, or individuals.¹⁷
- V. Security Categorization. The process of determining the **Security Category** for information or an information system.¹⁸
- W. Service Owner. A Service Owner is responsible for the delivery (design, performance, integration), continual improvement and management of assigned IT services.
- X. Token. Something that the Claimant possesses and controls (typically a key or password) that is used to authenticate the Claimant's identity.¹⁹
- Y. User. An individual or (system) process authorized to access an information system.²⁰

V. Authority

¹⁴ "NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations," U.S. Department of Commerce National Institute of Standards and Technology, April, 2013 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

¹⁵ *Ibid.*

¹⁶ *Ibid.*

¹⁷ "FIPS 199, Standards for Security Categorization of Federal Information and Information Systems." U.S. Department of Commerce National Institute of Standards and Technology, February 2004 <<https://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.199.pdf>>.

¹⁸ "NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations," U.S. Department of Commerce National Institute of Standards and Technology, April, 2013 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

¹⁹ Grassi, Paul A., Michael E. Garcia, James L. Fenton, "NIST Special Publication 800-63-3, Digital Identity Guidelines," U.S. Department of Commerce National Institute of Standards and Technology, June 2017 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-63-3.pdf>>.

²⁰ "FIPS 200, Minimum Security Requirements for Federal Information and Information Systems." U.S. Department of Commerce National Institute of Standards and Technology, March 2006 <<https://csrc.nist.gov/publications/fips/fips200/FIPS-200-final-march.pdf>>.

ORC 125.18

VI. Resources

Document Name	Location
NIST Special Publication 800-53, Security and Privacy Controls for Federal Information Systems and Organizations	https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf
Ohio IT Standard ITS-SEC-02 Security Controls Framework	https://das.ohio.gov/technology-and-strategy/policies
Ohio Administrative Policy IT-13 Data Classification	https://das.ohio.gov/technology-and-strategy/policies

VII. Inquiries

Direct inquiries about this policy to:

Office of Information Security & Privacy
Office of Information Technology
Ohio Department of Administrative Services
30 East Broad Street, 39th Floor
Columbus, Ohio 43215

614-644-6860 | state.isp@das.ohio.gov

DAS Policies may be found online at
<https://das.ohio.gov/technology-and-strategy/policies>

VIII. Revision History

This policy shall be reviewed no less than every two years and updated as needed.

Date	Description of Change
07/12/2017	Original Policy
11/26/2018	Updated the exception request language to align with the current procedure.
01/19/2021	Updated Multifactor Authentication, User Identifier, and device Identifier requirements. NIST SP 800-53 control family references were added to the requirements. Modified the compliance section to reflect the changes. The

Date	Description of Change
	template, branding, references, organizational terms and definitions were also updated.
09/14/2021	Conducted routine maintenance review of citations and references.
03/05/2024	Updated the policy template. Added a revision history review frequency statement.
04/29/2025	Replaced the term sensitive data, or sensitive information, with confidential data.